

Privacy-Preserving Recommendation Systems

Mid-Term Project Report

Mainak Sarkar (230619)

Shrasti Dwivedi (230982)

Aditya Anand (230065)

Shravan Agrawal (230984)

CS670, IIT Kanpur • 12 September 2026

Project status

OblivRec composes the two systems the instructor pointed us to: NUDGE’s three-server private matrix factorisation with PIRSONA’s DPF-based private retrieval. The composition is the contribution — NUDGE’s own non-goals state that it “*relies on other means . . . to let users fetch data items in a private way*”, while PIRSONA’s training core is superseded, so each paper leaves open precisely what the other supplies.

Since the survey we have built and verified the **serving and delivery half (S1)** end to end on MovieLens-100K, against a model factorised in the clear. The demo splits a user’s embedding across three servers — three separate OS processes, over TCP — scores all 1682 items locally on each, lets the user reconstruct and select the top ten, then fetches each record by two-server DPF-PIR: ten real film titles, each byte-exact against a cleartext lookup and matching an independent Python oracle position for position. Private *training* (S2) starts now; no claim is made about it here.

The strongest result is a measurement neither base paper reports. Because NUDGE publishes the item embedding matrix in the clear *by design*, an observed fetch is not one bit of information but a projection onto a known basis: **ten observed fetches recover a user’s private embedding to $\cos = 0.84$ and predict 56% of their next twenty recommendations**. That is the quantitative reason the delivery layer must be private at all.

Per-member contributions

Mainak Sarkar (230619) — W1, FSS core and delivery

Wrote the implementation and all report material to date; every commit in the repository is evidence for this section.

- **Distributed point function** (Boyle–Gilboa–Ishai), written rather than imported, templated on the ring from the first commit. Verified *exhaustively*: every α against every x to 16 domain bits at $b=64$ and 15 at $b=128$ — 7.16×10^9 leaf checks in 27 minutes. Keys are **227 B** at the demo’s operating point against 16 KB for a naive query.
- **Found and fixed a real security bug** in key generation: it seeded a Mersenne Twister and used the output as DPF seed material. The seeds *are* the secret and MT19937 is reconstructible from 624 outputs, so an adversary with enough key material could rebuild the GGM tree and recover α . Replaced with the OS CSPRNG, abort-on-failure.

- **Catalogue and DPF-PIR read layer.** Fixed-width 256 B records with explicit length prefixes. A server answer is one EvalFull plus an unconditional inner product — no data-dependent branch, and no data *pattern* either, since every expanded coefficient is a pseudorandom share.
- **Serving under secret sharing.** 2-of-3 replicated shares, with $\mathbf{a} \cdot \mathbf{B}$ computed locally per server — no communication and no multiplication protocol, because $\mathbf{B}$ is public. All **1682 scores match the Python oracle bit for bit**.
- **Three servers on the wire, and an adversary shown failing.** Separate OS processes over length-prefixed TCP; the networked run returns the same ten titles as the in-process one. Over 1800 recorded queries every frame is 228 B whatever the record index, and a classifier on the raw wire bytes scores 0.490–0.500 with chance inside every interval.
- **The leakage analysis** above, with a *popularity control* so the result cannot be an artefact of popular items sitting near everyone’s top: the identical estimator run on globally-popular items reaches only 0.26–0.53, and the attack’s margin over it is a stable +0.39 to +0.42 at every j . Also measured the obvious alternative to a private read and **showed it fails**: decoys must be popularity-weighted to be unremarkable, so they point where the control already points, and 40 of them (5× the traffic) still leave the adversary at 0.71 against a 0.44 floor.
- **Cost accounting (B1/B5 baselines) and the threat model.** DPF-PIR sends **446× fewer bytes** than downloading the catalogue, but is the *slowest* of the three in server CPU; the report states the crossover (8.0 Gbit/s) rather than showing only the flattering panel. Threat model in docs/threat-model.md.
- **Four real bugs found by tests rather than by inspection**, including a Python/C++ rounding-mode disagreement at every half-quantum, and a quantise-then-multiply error that shifted 1650 of 1682 reference scores by an amount *any tolerance-based check would have accepted*.
- **Verification infrastructure:** 9 test binaries green in 1.8 s and clean under UBSan trap mode, _GLIBCXX_DEBUG and a bounds-checked Span; a JSONL benchmark harness; and make figures, so no figure is ever hand-edited.
- **Report material:** all 11 sections of the survey, the bibliography (66 DBLP-verified entries), and the 20-page technical report.

Shrasti Dwivedi (230982) — W3, factorisation and serving

Aditya Anand (230065) — W2, 3PC substrate

Shravan Agrawal (230984) — W4, evaluation and security

Next steps before 6 November

Private training (S2) is the remaining half and begins now: secret-shared power iteration, with Trunc_t and ApproxNormalize as the only interactive steps. Phase 2 closed with its exit criterion met in full. What remains open from it is named rather than quietly dropped: wide-area measurement, which needs network emulation this machine lacks, and the inter-frame *timing* channel, which the distinguisher does not analyse. Schedule in PHASES.md; handover in docs/HANDOVER.md.